

허니팟 기반 사이버 공격 분석 시스템

공격자를 유인해 기록하는 것까지는 오픈소스가 해준다. 그 영문 로그를 **비전문 관리자가 그대로 읽고 바로 조치할 수 있는 한국어 위협 보고**로 자동 변환하는 4단 파이프라인을 만들었다.

기반 T-Pot 24.04.1 구성 컨테이너 10 · 사이드카 4 코드 약 8,600줄 기준일 2026-09-16 (v2.4)

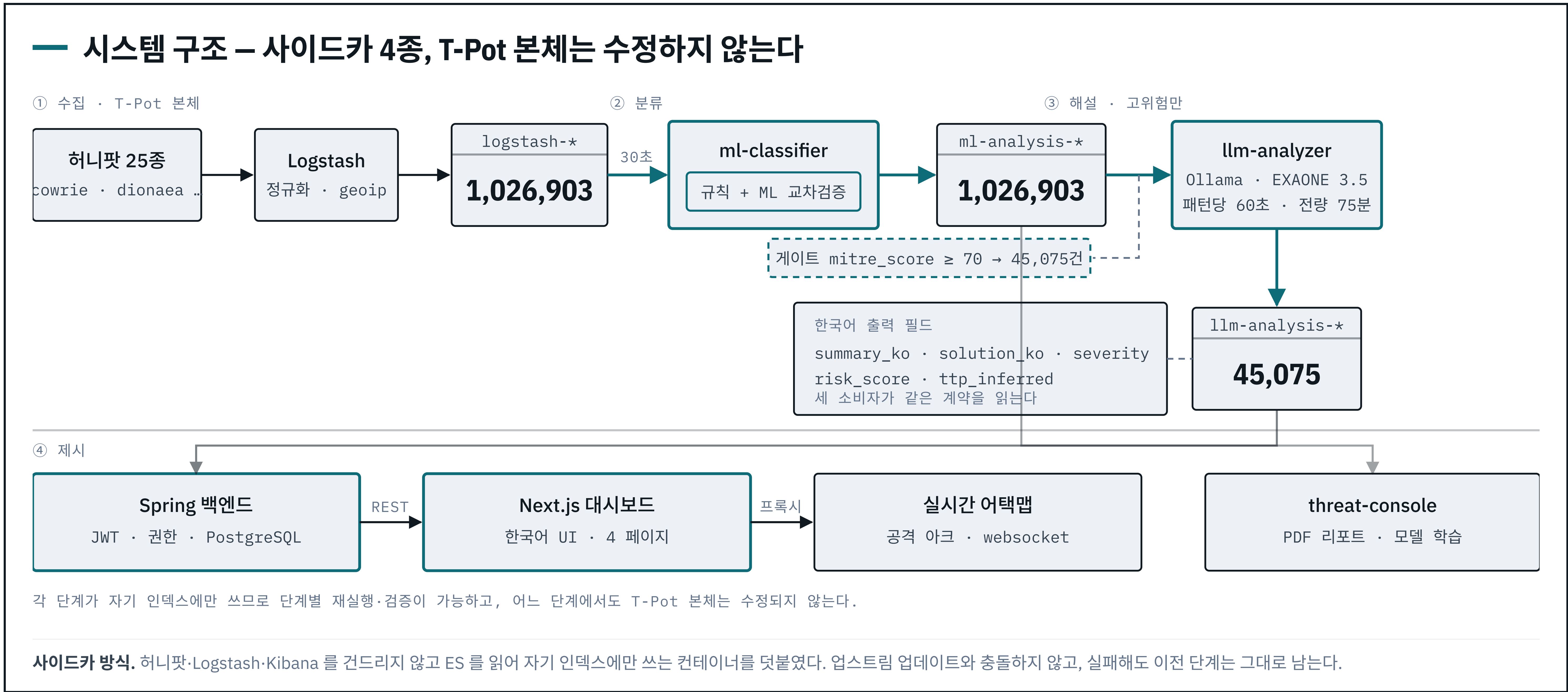
— 허니팟이란, 그리고 무엇이 비어 있었다

허니팟은 일부러 취약하게 열어둔 미끼 시스템이다. 실제 서비스가 아니므로 여기 들어오는 접속은 정의상 전부 비정상이고, 그래서 **오탐이 거의 없는 공격 정보**를 얻는다. 공격자가 가짜 셸에 `wget` 으로 악성코드를 내려받으면 **그 명령이 그대로 기록된다** — 실제 시스템은 안전한 채로.

T-Pot 은 허니팟 25종을 묶어 로그를 쌓아준다. 수집은 이미 해결돼 있다. 그러나 남은 것은 `cowrie.login.failed` 같은 영문 원시 이벤트뿐이고, 이를 "무슨 일이 있었고 뭘 해야 하나"로 옮기려면 허니팟별 스키마와 MITRE 를 이미 알아야 한다.

목표는 **그 해석을 자동화하는 것이다**. 모든 이벤트에 공격 유형과 위협 점수를 매기고, 고위험 건은 한국어 요약과 대응 방안까지 만들어 대시보드에 올린다. 전담 보안 인력이 없는 조직도 자기 대역을 노리는 공격을 한국어로 통보받는다.

수집 이벤트 1,026,903 실제 공격 10일	고유 공격 IP 24,346 수집 지점 18종
고위험 선별 45,075 전체의 4.4%	모델·규칙 합의 99.9% 불일치 782건



— ML 을 켤 수 있게 만든 과정

holdout **0.998** 인데 실제 문서는 전부 **Recon** 이었다. 원인은 모델이 아니라 **라벨**이었다.

① 원본	35.4%
② 라벨 재균형	35.4%
③ 세션 조인	61.4%
④ 라벨러 개선	79.0%

규칙 대비 일지출. 라벨러가 경보 없는 행 **73%** 를 정찰로 부르고 있었다. 리버스셸인데 Intrusion 이 아니던 행은 **322/384 → 0/384** 가 됐다.

⑤ 실 문서로 학습 — 가설이 맞았다
CSV 학습본은 Malware 3,450건 중 3,328건 을 Intrusion 으로 불렀다 — 두 클래스를 가르는 특징이 전부 0 이었다. 실 문서로 다시 학습하니 사라졌다.

활성화 방식: 규칙이 기준선, 모델은 뒤집지 못한다. **1,026,903건 전량 합의 99.9%** — 값어치는 합의율이 아니라 **불일치 782건이 검토 큐로 떠오른다**는 데 있다.

남은 불일치도 한쪽으로 몰린다
782건 중 707건이 Suricata 이고, 규칙이 Malware(414) · Intrusion(194) 이라 한 것을 모델이 Recon 으로 낮춰 본다. 다음 개선 지점이 그대로 보인다.

— LLM 모델을 측정해서 골랐다

`mitre_score` 92 인 문서에 모델이 `severity: LOW` 를 반환했다. **고치기 전에 잤다** — 프롬프트 문제와 능력 문제는 해법이 다르다.

qwen2.5:3b	0 / 10
qwen2.5:7b	2 / 10
EXAONE 3.5	10 / 10

고위험 10건의 위험도 판정 정확도. EXAONE 은 한자 혼입 **0/10**, MITRE 기법도 정답이었다.

설계 원칙
3B→7B 가 0%→20% 에 그쳤다. 위험도는 단순 대응표인데 모델을 키워도 안 맞는다 — 애초에 LLM 에게 맡길 일이 아니었다. 점수에서 계산하고 모델에는 문장만 맡긴다.
같은 이야기를 4만 번 쓰고 있었다
고위험 45,075건은 실제로 74개 공격 패턴 이고 상위 2개(둘 다 포트 445)가 89.8% 다. 패턴당 한 번만 해설하도록 고쳐 31.8일 → 75분 , 상위 3개면 3분에 90% 가 덮인다.

그대로 재사용하면 안 됐다. 프롬프트가 IP·시각을 주입해 모델이 본문에 박으므로 **22,391건에 틀린 값이 박힌다**. 패턴 프롬프트에서 둘을 빼 **모델이 못 본 값은 지어낼 수 없게** 했다. 저장해두니 **부를 일도 없다** — 고위험 12건이 모두 해설을 갖고 있었다. **42ms**(추론 60초).

라이선스 주의: EXAONE 은 비상업(NC). 상업화하면 Apache-2.0 모델로 되돌려야 하고 한국어 품질이 떨어진다.

— 실제로 돌려서 확인했다

파이프라인 4단 · 컨테이너 10 · API·프론트·어택맵 전부 200

• 동작
가장 비쌌던 건 조용한 실패 4건
<code>int("23.0")</code> 예외로 포트가 전부 0, Suricata payload 미조 회로 명령 특징 소실, ES 동적 매핑으로 집계가 빈 차트에 삼켜짐, 낮은 확신도를 Normal 로 바꿔 미지의 공격이 사라짐 — 넷 다 예외도 경고도 없었다.

— 내 자산은 실제로 맞고 있나

445 · SMB	고위험 40,487
22 · SSH	고위험 0

허니팟이 본 건 **우리 대역을 노리는 공격**이지 우리가 뚫렸다는 뜻이 아니다 — **열어둔 포트를 대야 내 얘기가 된다**. SSH 는 13,801건을 두드려도 고위험 0 이라 **"안 맞고 있다"** 도 답이다. `dest_port` 만 있으면 되므로 ML 도 LLM 도 쓰지 않는다.

— 상업화하려면 넘어야 할 선

- 라이선스 — T-Pot 은 GPL-3.0. 제품 판매는 막히고 관제 서비스만 열린다
- 추론 비용 — 패턴 단위 해설로 **74회 호출(75분)**. 단가는 트래픽 양이 아니라 패턴 다양성에 비례한다
- 다중 테넌시 — 단일 조직 전체. 격리·SLA 가 없다